

NARRATIVA EXPLICATIVA: EL ARTE (IRÓNICO) DE MEDIR LO INMENSURABLE

Por qué los números cibernéticos son el nuevo oráculo empresarial

PRÓLOGO: LA PARADOJA DE SÓCRATES EN LA ERA DIGITAL

Sócrates, aquel señor griego aficionado a hacer preguntas incómodas en las ágoras, estaría de lo más entretenido contemplando el espectáculo contemporáneo de las organizaciones españolas intentando *responder* preguntas sobre ciberseguridad.

Porque aquí está la risa histórica: **Hace treinta años**, los CISO (Chief Information Security Officers) no existían. Las empresas instalaban un firewall, lo olvidaban detrás de un armario, y confiaban en que la magia del enrutamiento hiciera que los hackers se aburrieran.

Hace quince años, apareció el primer regulador tímido (LSSI-CE) con gafas bifocales, pidiendo por favor que documentaran *algo* sobre seguridad. Las organizaciones respondieron con documentos de Word que parecían redactados por IA con depresión.

Hoy en 2026, nos encontramos en la tercera acepción del diccionario de caos: **La Era del Cuestionario Infinito**. Y esta encuesta, amigos, es la más hermosa manifestación de esa paradoja.

CAPÍTULO I: POR QUÉ MEDIMOS LO QUE NO PODEMOS VER

La Maldición de Schrödinger Corporativo

Imaginemos un banco español de tamaño mediano. ¿Sabe si su ciberseguridad es buena? Veamos:

- El Director General piensa que sí, porque gastaron €500K en "seguridad" el año pasado (sin saber en qué).
- El CISO sabe que no, porque detectó 47 vulnerabilidades críticas el mes pasado que nadie sabía que existían.
- El Auditor Externo está confundido, porque su checklist de ISO 27001 dice "sí" a todo (si miente suficientemente).
- El Regulador (AEPD, CCN-CERT) no tiene ni idea, pero envía un email amenazante cada seis meses.

Conclusión: La organización existe simultáneamente en cinco estados de seguridad hasta que alguien sufre un ataque ransomware. Entonces colapsa hacia la realidad: **ESTADO = NULO**.

Esta encuesta es nuestro intento de sacar al gato de Schrödinger de la caja antes del incidente.

La Ilusión del Control Cuantitativo

Humanos somos animales de números. Si no podemos medir algo, asumimos que no existe.

- No puedes ver un malware → Lo mides en detecciones/hora
- No puedes tocar una vulnerabilidad → La puntúas con CVSS (0-10)

- No puedes sentir la resistencia de un empleado → La conviertes en "click rate de phishing" (%)

Pero aquí está el truco: **Los números no son la realidad. Son la representación política de la realidad.**

Cuando un CISO dice "Tenemos 1.500 alertas SIEM diarias", ¿qué significa realmente?

- Opción A: Detección excelente de amenazas
- Opción B: SIEM mal konfigurado generando ruido
- Opción C: Infraestructura tan ruidosa que nadie oye las alarmas reales
- Opción D: Todas las anteriores

Esta encuesta intenta transformar esa ambigüedad en claridad.

CAPÍTULO II: LOS CINCO PECADOS CAPITALES DE LA AUTOEVALUACIÓN

Pecado 1: El Optimismo Corporativo (Sesgo +0.3 puntos)

Cuando un responsable de seguridad se sienta frente a un cuestionario, una fuerza mágica lo posee. De repente:

- "No tenemos SIEM" → "Tenemos un SIEM casero" (+2 puntos)
- "Los escaneos son anuales" → "Los escaneos son continuos-ish" (+1.5 puntos)
- "La capacitación fue hace años" → "Tenemos un programa en mente" (+2 puntos)

La realidad: Las organizaciones suelen anotar 0.2-0.4 puntos más de lo que merecen. Por eso existe esta guía de interpretación.

Pecado 2: La Confusión entre Aspiración y Ejecución

Pregunta: "¿Existe un Plan de Continuidad de Negocio?"

Respuesta honesta (Tier 1): "Eh... no."

Respuesta típica española (Tier 2): "Bueno... tenemos un documento. Nadie lo ha abierto desde 2019, pero existe."

Respuesta peligrosa (Tier 3): "Sí, lo probamos el año pasado." (Verdad: Lo probaron durante 15 minutos, falló, decidieron no hablar de ello).

CAPÍTULO III: LA ALQUIMIA DE LA CONVERSIÓN DE NÚMEROS EN DINERO

El Teorema de Mercury AVRQ

Aquí es donde la narrativa se vuelve verdaderamente hermosa: **Convertir riesgo cibernético en impacto financiero.**

Tradicionalmente, un CISO decía: "Tenemos vulnerabilidades críticas."

El Director Financiero respondía: "¿Y eso en qué me afecta?"

El CISO, en silencio interno: "ARGH."

Llegó Mercury AVRQ:

"Tú tienes 47 servidores de valor €2M. Tu tasa de incidente es 15%/año. El impacto promedio es €500K. Por lo tanto, tu riesgo residual es: $€2M \times 15\% \times 50\%$ (mitigación actual) = €150K/año que no estás protegiendo."

De repente, el Director Financiero entiende. Porque es dinero. Hermoso, puro, quantificado dinero.

El Retorno sobre la Inversión: La Última Bruja

Inviertes €100K en SIEM. ¿Qué esperas?

- Opción tradicional: "Que no nos hackeen" (no-cuantificable)
- Opción Mercury: "Que detectemos amenazas 4 horas más rápido (reduciendo daño en €200K), que nos evitemos una sanción NIS2 (potencial €500K), y que aceleremos respuesta en 2 horas (beneficio €80K)"

Resultado: $ROI = (200K + 500K + 80K - 100K) / 100K = 680\%$

¿Ves? Magia números.

CAPÍTULO IV: LA VERDADERA BELLEZA ESTADÍSTICA

Por Qué Estos Datos Importan (Y Por Qué Probablemente No Los Leerá Tu Junta)

Esta encuesta produce un número: tu **Índice Global de Madurez (IGM)**.

- $IGM = 2.3$ → "Somos normales"
- $IGM = 3.7$ → "Somos buenos"
- $IGM = 4.8$ → "Somos excepción genética" (0.3% de las organizaciones)

Pero aquí está lo verdadero: **Ese número no es un juicio moral.**

Es un mapa. Un espejo. Una brújula hacia "menos probable que nos ataque un oso en el próximo trimestre."

La Verdad Incómoda: Las Organizaciones Españolas

Basándose en benchmarks 2024:

- Sector Financiero: IGM promedio 3.2 (Por regulación. Si no fuera obligatorio, sería 2.1)
- Sector Sanidad: IGM promedio 2.8 (Equipamiento desactualizado, personal abrumado)
- Administración Pública: IGM promedio 2.5 (Presupuestos políticos, no técnicos)
- Tecnología: IGM promedio 3.9 (Porque si no lo hacen, sus clientes se fugan)

Conclusión: España está en Tier 3 (Establecido, pero sin optimización). Es decir: *Mejor que 2019. Peor que debería ser dado el riesgo.*

CAPÍTULO V: LOS DOMINIOS: UNA SINFONÍA EN DOCE MOVIMIENTOS

Dominio Gobernanza y Riesgos (GR): El Corazón Oscuro de la Estrategia

Si este dominio está mal, todo lo demás es performance teatral. Porque sin gobierno:

- Tienes controles sin propósito
- Dinero gastado sin ROI
- Incidentes sin lecciones
- Política de seguridad que nadie lee

Ironía: La mayoría de organizaciones invierten 80% en tecnología (SIEM, firewalls, EDR) y 20% en gobernanza. Debería ser al revés.

Dominio Vulnerabilidades (VUL): La Carrera Eterna contra lo Inevitable

Aquí es donde ves la verdad: "**¿Cuántas vulnerabilidades tienes?**"

Respuesta honesta: "Infinitas. Literalmente encontramos nuevas cada día."

Respuesta útil: "Encontramos 47 críticas/mes. Remediamos 41/mes. Acumulamos 6 críticas mensuales."

Moraleja: No se trata de tener cero vulnerabilidades (imposible). Se trata de: ¿Detectas más de lo que se abre? ¿Las remedia más rápido de lo que envejecen?

Dominio SIEM e Incidentes: El Pánico Convertido en Arte

Un SIEM genera 10.000 alertas diarias. Tu equipo revisa 50. ¿Qué pasa con las 9.950?

Respuesta: Se pierden en el ruido digital. Y en ese ruido, a veces, hay un ataque real que pasa desapercibido.

La métrica importante: No "**¿Cuántas alertas generamos?**" sino "**¿Cuál es la probabilidad de que un ataque crítico pase desapercibido?**"

CAPÍTULO VI: CAPACITACIÓN DE EMPLEADOS: LA ÚLTIMA MURALLA

Aquí es donde lo técnico se vuelve humano. Porque un atacante no necesita vulnerabilidad de código para entrar:

Juan del Departamento Comercial recibe email:

"Estimado Juan, tu contraseña necesita verificación urgentemente. Haz clic aquí."

Juan, pobre, hace clic. No porque sea tonto. Sino porque está cansado, tiene deadline de mañana, y confía.

La encuesta te pregunta: ¿Cuántos Juanes tienes? ¿Y cuántos han recibido verdadera educación? (No checklist de compliance, sino *educación real*)

La realidad irónica: Las empresas invierten €500K en firewalls. Y las breach statistics muestran que el 91% de ataques comienzan por error humano.

Es como gastar millones en cerraduras mientras dejas la puerta abierta.

CAPÍTULO VII: CUMPLIMIENTO NORMATIVO: LA DANZA DEL MIEDO

NIS2, GDPR, ISO 27001, LSSI-CE, AEPD, CCN-CERT...

Es como vivir en una casa donde cada pared tiene un policía diferente. Y todos hablan idiomas ligeramente distintos.

- NIS2 dice: "Notifica incidentes en 24h"
- GDPR dice: "Notifica brechas en 72h"
- Regulador español dice: "Depende"

La verdad: Cumplimiento no es checkbox. Es diseño de procesos que *coincidan* con requisitos.

Esta encuesta identifica dónde no coinciden. Y ese es el lugar donde vives al borde del precipicio regulatorio.

EPÍLOGO: LA PREGUNTA FINAL DE SÓCRATES

¿Y si Sócrates volviera hoy y viera esta encuesta?

Probablemente sonreiría. Porque lo que hacemos es fundamentalmente socrático: **Crear preguntas que revelan la ignorancia que pensábamos que no teníamos.**

Y luego, como Sócrates, queremos transformar esa ignorancia revelada en sabiduría.

No perfecta. No completa. Pero mejor que ayer.

CODA: TRES VERDADES QUE ESTA ENCUESTA NO PUEDE MEDIR (PERO SABE QUE EXISTEN)

Verdad 1: La Madurez No Es Lineal

Un banco de €10B puede tener IGM 3.2. Una startup de cybersecurity de €5M puede tener IGM 4.6.

Porque la madurez depende de *visión*, no de *presupuesto*. (Aunque presupuesto ayuda.)

Verdad 2: Lo Más Importante Es Invisible

El ataque que *no ocurrió* porque detectaste la anomalía a las 3:17 AM. La brecha que se evitó porque un empleado reportó una llamada sospechosa. La vulnerabilidad que nunca exploró nadie.

Esos números: incalculables. Incuantificables. Reales.

Verdad 3: Esta Encuesta Es Obsoleta Desde el Momento en que la Completas

Mañana habrá una vulnerabilidad nueva. La próxima semana, una regulación adicional. El mes que viene, un ataque que necesitará nuevas defensas.

Pero eso está bien.

Porque lo que sí puede medir esta encuesta es esto: **¿Tienes los procesos, las personas, la gobernanza, la tecnología para adaptarte a lo desconocido?**

Esa es la verdadera ciberseguridad. No la perfección. La **resiliencia en movimiento**.

INSTRUCCIONES FINALES PARA EL USUARIO

Cuando completes esta encuesta, no busques puntuación perfecta. Busca:

1. Honestidad: Di la verdad, aunque duela.
2. Especificidad: "No sé" es mejor respuesta que "probablemente sí".
3. Reflexión: Estas preguntas van a hacer que tu equipo hable de cosas incómodas.
4. Acción: El número final no importa. Lo que importa es qué haces después.

Y cuando obtengas tu IGM, recuerda: **No es tu calificación. Es tu brújula.**

Narrativa escrita con una sonrisa irónica, basada en 25 años de observar cómo las organizaciones luchan con lo invisible, lo cuantificable y lo inevitable.

Enero 2026, desde las minas de carbón de la ciberseguridad española

FIN